iCReaT 보안 취약점 자체점검 보고서

Nov 5, 2026 · 작성 @길윤정

이 문서는 운영 담당자 관점에서 수행하는 **방어적 보안 자체점검(threat modeling)** 결과다. 라이브 시스템에 대한 실제 침투 시도가 아니라, 외주 운영사 소명 요구와 내부 보안 강화에 바로 쓸 수 있는 위협 모델·점검 체크리스트·대응 권고로 구성한다.

- **적용 기준**: OWASP API Security Top 10 (2023), OWASP ASVS 4.0, 개인정보보호법·개인정보 안전성 확보조치 기준, ISMS-P 인증기준
- **대상 특성**: 임상·개인식별·건강정보를 다루는 공공 연구 플랫폼 → 침해 시 개인정보보호법상 민감정보 유출에 해당, 법적·사회적 파급 매우 큼
- **위협 수준 표기**: Critical(즉시 조치) / High(단기 조치) / Medium(계획적 조치)
- **읽는 법**: 각 축은 ①예상 공격 기법·위협 수준 ②영향 분석 순으로 정리했고, 외주사 질의서(6장)와 기술 권고안(7장)에서 종합한다.

> 주의: 아래 '점검 관점 시나리오'는 "무엇이 뚫릴 수 있는가"를 방어자가 확인하기 위한 가설이다. 실제 검증은 반드시 사전 승인된 범위·격리된 환경에서, 권한 있는 보안 담당자(또는 정식 모의해킹 용역)가 수행해야 한다.

1. 권한 상승 (BOLA / Privilege Escalation)

위협 수준: Critical. 공공 임상데이터 플랫폼에서 가장 빈번하고 치명적인 결함 유형이다(OWASP API #1 BOLA, #5 BFLA, #3 BOPLA).

예상 공격 기법 (점검 관점 — 무엇을 확인해야 하는가)

- **수평적 권한 우회(BOLA)**: 정상 권한의 담당자가 조회·다운로드 요청의 식별자(과제 ID, 대상자 ID, 파일 ID 등)를 자신의 것이 아닌 값으로 바꿔 요청했을 때, 서버가 "이 사용자가 이 객체의 소유/소속 권한을 갖는가"를 검증하지 않고 응답하는지. 식별자가 순차증가(1,2,3…)·추정가능 형식이면 위험이 더 크다.
- **수직적 권한 우회(BFLA)**: 일반 담당자 계정으로 관리자 전용 기능·메뉴·API 엔드포인트(전체 과제 일괄조회, 사용자 관리, 설정)에 직접 호출이 통하는지. UI에서 메뉴를 숨기는 것과 서버가 권한을 거부하는 것은 다르다 — 서버측 강제가 없으면 메뉴만 가린 것은 무력하다.
- **파라미터·역할 변조**: 요청 본문·쿠키·JWT 클레임의 role/권한 필드를 클라이언트가 바꿔 보낼 때 서버가 이를 신뢰하는지. 권한 판단 근거가 클라이언트에서 오면 안 된다.
- **대량 파라미터 주입(Mass Assignment)**: 프로필·과제 수정 시 전송하지 않아야 할 필드(role, isAdmin, ownerTaskId)를 끼워 넣으면 그대로 반영되는지.

영향 분석

- 단일 과제 격리 원칙이 무너지면, 한 명의 일반 담당자가 전체 과제의 임상·개인정보를 열람·다운로드할 수 있어 격리의 의미가 사라진다.

- 수직 상승이 성립하면 사실상 Super Admin 권한 탈취와 동일 — 전수 데이터 일괄 반출, 계정·설정 변조로 이어진다.
- 개인정보보호법상 민감정보 대량 유출 사고로, 신고·통지 의무 및 과징금 대상이 된다.

2. 백도어 및 외주사 관리통로 (Shadow Access)

위협 수준: High–Critical. 외주 개발·운영 구조에서는 정규 인증 체계를 우회하는 지속 경로가 남아있기 쉬우며, 이는 정상 권한 체계를 무효화한다.

예상 위협 지점 (점검 관점)

- **하드코딩된 계정·비밀번호**: 소스·설정파일·DB에 개발용·유지보수용 계정, 기본 비밀번호(admin/admin 등), API 키가 삽입된 채 운영으로 넘어갔는지.
- **테스트·디버그용 잔존물**: 개발 단계 테스트 계정, 디버그 엔드포인트, 주석 처리되지 않은 관리 페이지, Swagger/정보성 API 문서가 운영망에 노출된 채 남아있는지.
- **원격 유지보수 채널**: 외주사가 사용하는 원격 접속 경로(VPN, 밟션호스트, SSH, RDP)의 계정·접근제어·로깅이 운영 검수 범위에 들어있는지, 공유 계정(계정 1개를 여러 명이 사용)인지.
- **백업 시스템 접근**: 백업 저장소(파일·DB 덤프)에 접근할 수 있는 계정·위치·암호화 여부. 백업은 종종 운영보다 통제가 느슬해 전체 데이터가 평문으로 빠져나가는 지점이 될 수 있다.
- **공급망(Supply Chain)**: 외주사의 빌드·배포 파이프라인, 사용 중인 오픈소스 라이브러리 가시성 확보 여부.

영향 분석

- 백도어·하드코딩 계정은 정상 인증·권한 통제를 전부 우회해 "적법한 접근"으로 위장된 침해를 가능하게 한다.
- 외주사 내부자 위협(퇴사자 계정 미회수 등)와 공유계정 사용은 책임추적(누가 했는가)을 불가능하게 만든다.
- 발주자로서 기관은 외주사 관리 부실에 대해서도 최종 책임을 진다 — 계약서·SLA·보안서약으로 통제할 사항이다.

3. 세션·인증 관리 허점

위협 수준: High. 3개월 비밀번호 변경 주기는 정책일 뿐, 그 자체로 브루트포스·세션 탈취를 막지 못한다.

예상 공격 기법 (점검 관점)

- **브루트포스·크드션스터핑**: 로그인 시도 횟수 제한, 계정 잠금, CAPTCHA, 일정 실패 후 지연이 없으면 주기적 비밀번호 변경은 무의미해진다. 다른 사이트 유출 자격증명을 대입하는 크드션스터핑도 포함.
- **세션 고정(Session Fixation)**: 로그인 전후로 세션 식별자가 재발급되는지. 재발급되지 않으면 공격자가 미리 심은 세션으로 피해자 계정을 탈취할 수 있다.

- **세션 권한/만료 취약**: 세션 타임아웃·유휴 만료·동시접속 제어·로그아웃 시 서버측 무효화가 정상 동작하는지. 쿠키에 Secure·HttpOnly·SameSite 속성이 설정되어 있는지.
- **전송구간 보호**: TLS 버전·암호 스위트 강도, HSTS 적용 여부. 중간자 공격으로 세션 쿠키·토큰이 노출되면 주기적 비밀번호 변경과 무관하게 계정이 탈취된다.
- **비밀번호 정책 품질**: 주기적 변경만 강제하고 복잡도·연속성·재사용 금지·유출 비밀번호 대조(HIBP)가 없으면, 사용자는 'P@ssword1 → P@ssword2' 식으로 회피해 보안이 오히려 약화된다.
- **다층인증(MFA) 부재**: 관리자·외부 접속에 MFA가 없으면 비밀번호 단일 요소 탈취로 계정이 뺑린다.

영향 분석

- 세션·인증 우회는 '정당한 사용자'로 위장된 접근을 허용해, 이후 단계의 BOLA·데이터 반출의 교두보가 된다.
- 관리자 계정이 브루트포스로 뚫리면 전체 시스템 장악으로 이어지는 단일 실패지점이 된다.

4. 정보유출·파일 다운로드 로직 (IDOR)

위협 수준: Critical. 대용량 임상 데이터 다운로드 경로는 가장 직접적인 대량 유출(exfiltration) 표면이다.

예상 공격 기법 (점검 관점)

- **IDOR 형 다운로드 URL**: 다운로드 링크가 `?fileId=1024` 처럼 추정·열거 가능한 식별자만 담고 있고, 매 다운로드마다 '이 사용자가 이 파일 권한을 갖는가'를 재검증하지 않는지.
- **서명·만료 없는 직통 URL**: 클라우드 스토리지(S3 등) presigned URL이나 임시 다운로드 토큰이 만료시간·사용횟수 제한 없이 발급되면, 한 번 노출된 URL이 재사용·공유된다.
- **열거·스크래핑(Enumeration)**: 식별자가 순차적이면 자동화 스크립트로 ID를 1씩 증가시켜 전체 파일을 긁어갈 수 있다. 요청 속도 제한(rate limit)·이상행위 탐지가 없으면 탐지도 안 된다.
- **과다 응답(Excessive Data Exposure)**: API가 화면에 필요한 것보다 많은 필드(주민번호, 내부 식별자, 전체 레코드)를 내려보내고 클라이언트에서만 가리는지.
- **대량 요청 제한 부재(Unrestricted Resource Consumption)**: 페이징 상한·대용량 일괄다운로드 횟수 제한이 없으면 한 계정으로 전수 데이터를 단시간에 빼낼 수 있다.

영향 분석

- IDOR+스크래핑 조합은 '한 건 유출'이 아니라 '전수 유출'로 번진다 — 임상시험 참여자 전체의 건강정보가 한 번에 다운로드될 수 있다.
- 로그인 후 정상 다운로드처럼 보이기 때문에 경계보안장비(WAF)만으로는 감지가 어렵다 — 기능 권한 검증과 이상행위 탐지가 함께 있어야 한다.

5. 관리자 모니터링·감사로그 결함

위협 수준: High. OWASP API #9(부적절한 로깅·모니터링). 감지 공백은 침해를 막지 못할 뿐 아니라 사고 후 원인추적·법적 대응까지 불가능하게 만든다.

예상 결함 (점검 관점)

- **감사로그 범위 부족**: 로그인·권한변경·대량다운로드·관리자 조작·설정변경·인증실패가 누가·언제·어디서·무엇을 단위로 남는지. 가장 빈번한 결함은 '조회·다운로드 행위가 로그에 없는' 경우다.
- **로그 무결성 미보장**: 로그가 운영·관리자 권한으로 수정·삭제 가능하면 침해자가 흔적을 지운다. 버키징·WORM·분리 저장·해시체인 여부.
- **실시간 탐지 부재**: 비정상 대량 다운로드, 사무시간 외 관리자 접속, 비승인 IP·해외 IP 접속, 급격한 권한 변경에 대한 알림(alerting) 규칙이 없는지. 로그는 쌓이지만 아무도 안 보는 '사후 참고용'에 그치는지.
- **관리자 이상행위 기준선 부재**: Super Admin은 원래 전체 접근이 정상이므로, '정상 관리자 행위 범위'를 기준선으로 두고 일탈(평소의 10배 다운로드 등)을 잡는 체계가 있는지.
- **보관 주기·책임분리**: 로그 보관 기간(개인정보 접속기록은 법상 최소 보관기간 준수 필요)과, 로그를 보는 주체와 시스템 운영 주체의 분리 여부.

영향 분석

- 로그·모니터링 결함은 단독으로는 유출을 일으키지 않지만, 앞선 모든 공격의 탐지·대응·사후추적을 불가능하게 만드는 증폭인자다.
- 개인정보보호법은 개인정보처리시스템 접속기록의 생성·보관·점검을 요구한다 — 로그 결함은 그 자체로 법적 미준수 사항이 될 수 있다.

6. 외주사 보안 점검 질의서 (소명 요구용)

아래는 개발·운영 외주사에 **서면 소명**을 요구할 항목이다. 각 항목은 "예/아니오"가 아니라 **증빙(설정값·로그·코드·정책문서 캐흑)**을 함께 제출하도록 요구해야 한다. 그래야 '조치했다'는 구두 답변을 막을 수 있다.

#	점검 항목	외주사에 요구할 증빙
1	모든 객체 접근(과제·파일·대상자)에 서버측 소유권 검증이 있는가(BOLA)	권한 검증 코드 위치·방식, 타인 ID 요청 시 차단 로그 샘플
2	관리자 전용 기능·API가 서버측 역할검사로 보호되는가(BFLA)	권한 매트릭스, 일반계정의 관리 API 호출 차단 테스트 결과
3	파일 다운로드 URL이 추측·재사용 불가한가(IDOR)	URL 구조, 토큰 만료시간·일회성, 순차ID 사용 여부

#	점검 항목	외주사에 요구할 증빙
4	하드코딩된 계정·비밀번호·API키가 없는가	비밀관리(Secret) 체계 문서, 정적분석·시크릿스캔 결과
5	테스트·디버그 계정·엔드포인트가 운영에서 제거되었는가	운영 계정 목록, API 엔드포인트 전체 목록, 비활성 증빙
6	원격 유지보수 경로가 통제되는가	접근 경로 도식, 계정·MFA·IP화이트리스트, 접속 로그
7	공유 계정 없이 개인별 계정·최소권한이 적용되는가	외주사 접근 계정 대장, 권한 부여 내역
8	백업 데이터가 암호화·접근통제되는가	백업 저장위치·암호화 방식, 백업 접근 권한·로그
9	로그인 실패 제한·계정잠금·MFA가 있는가	인증 정책 설정값, 실패 N회 후 동작 증빙
10	로그인 시 세션ID 재발급·안전한 쿠키 속성이 설정되는가	쿠키 속성(Secure/HttpOnly/SameSite), 세션 재발급 테스트
11	대량 다운로드·API 요청 속도 제한(rate limit)이 있는가	rate limit 설정값, 페이징 상한, 임계값 초과 시 차단
12	감사로그가 필수 행위를 빠짐없이 남기는가	로그 설계서, 다운로드·권한변경 항목 로그 실제 샘플
13	로그 무결성·보관기간이 보장되는가	로그 분리저장·변조방지 설정, 보관기간 정책
14	이상행위 실시간 알림(alert) 체계가 있는가	알림 규칙 목록, 최근 탐지·대응 이력
15	정기 취약점 진단·모의해킹·보안패치가 수행되는가	최근 진단 보고서, 취약점 조치 내역, 패치 이력

7. 즉시 적용 보안강화 권고안 (대응 매뉴얼 초안)

우선순위는 빠른 적용 가능성과 위험 차단 효과를 함께 고려했다.

즉시(1주 내) — 출혈 차단

1. 관리자·외부·외주사 접속에 **MFA 강제** 적용, 공유계정 폐기·개인별 계정 전환.
2. 로그인 **실패 횟수 제한·계정 잠금·CAPTCHA** 즉시 활성화(브루트포스 차단).
3. **하드코딩 계정·테스트 계정·디버그 엔드포인트** 스캔 및 제거, 기본비밀번호 일괄 변경.
4. 대량 다운로드·권한변경·관리자 접속에 대한 **실시간 알림 규칙** 설정(최소한 '평소의 N배' 임계치).

단기(1개월 내) — 권한·유출 경로 제거

1. 모든 조회·다운로드 API에 **서버측 객체·기능 권한 검증** 일괄 적용(클라이언트 role 신뢰 금지).

2. 파일 다운로드를 **만료시간·일회성 서명 URL + 매 요청 권한 재검증** 구조로 전환, 식별자를 비예측 값(UUID)으로 변경.
3. **API 요청 속도 제한(rate limit)·페이징 상한·대량다운로드 승인절차** 도입(스크래핑 차단).
4. 세션 **재발급·안전한 쿠키 속성(Secure/HttpOnly/SameSite)·HSTS** 적용, API 응답에서 불필요 민감필드 제거.
5. 감사로그 **분리·변조방지(WORM) 저장**으로 전환, 필수 행위 로깅 항목 표준화.

구조·거버넌스(분기 내) — 지속 체계

1. **최소권한 원칙·권한 정기 재검토**, Super Admin 일괄다운로드에 2인 승인·목적 기록 절차.
2. 외주사 대상 **보안서약(SLA)·정기 보안점검·비밀관리 체계·사고 통보 의무** 문서화.
3. **년 1회 이상 정식 모의해킹(외부 전문기관)** 및 주기적 취약점 진단, 결과 조치 이력 관리.
4. **ISMS-P 기준·개인정보 안전성 확보조치**에 맞춘 접속기록 보관·암호화·접근통제 정비.

본 문서는 방어적 자체점검 프레임워크이며, 실제 고유 취약점 검증은 권한 있는 보안 담당·정식 모의해킹 용역이 사전 승인된 범위에서 수행해야 한다.